

VULNERABILITY REPORT ASSESSMET

Prepared for OWASP Juice Shop
<https://juice-shop.herokuapp.com>

Prepare by
Oritonda Nimalale
Cybersecurity Intern
Future Interns

20
26

EXECUTIVE SUMMARY

A security assessment was conducted on the OWASP Juice Shop website between 05 May and 08 May 2026. This assessment focused on identifying common security vulnerabilities using only ethical testing methods. All testing was conducted through browser developer tools, during such time no active exploitations or attacks were actioned against the website

KEY FINDINGS :

Total Vulnerabilities found :	5
Low Risk :	2
Medium Risk :	3
High Risk :	0

BUSINESS IMPACT

No high risks were identified, but the identified risks create a surface for unnecessary attacks. The non-existent response headers and insecure cookies configurations create that surface. An attacker could possibly exploit these weaknesses to steal user sessions and inject malicious content.

PRITORITY RECOMMENDATIONS

- 1.Enable Strict-Transport-Security
- 2.Implement Content-Security-Policy Header
- 3.Add Secure and HttpOnly flags To All Cookies
- 4.Add Referrer-Policy Header
- 5.Adapt To Permissions-Policy Header

ASSESSMENT AND METHODOLOGY

Target URL:
https://juice-shop.herokuapp.com

Assessment Type:
Read-only/Passive

Assessment Date:
May 10,2026

CIN:
FIT/MAY26/CS8151

Tools Used:

TOOL

Brave DevTools

Manual HTML
Inspection

PURPOSE

- Header Analysis
- Cookie Inspection

- Comment
- Review

ETHICAL RULES FOLLOWED

- Public-facing pages only
- Passive scanning only
- No exploitation or active attacks
- No brute force attempts
- No denial of service
- No data modification

This assessment was done under a strict read-only methodology, simulating a security auditor rather than an attacker or hacker

FINDING #1 : MISSING CONTENT-SECURITY-POLICY HEADER

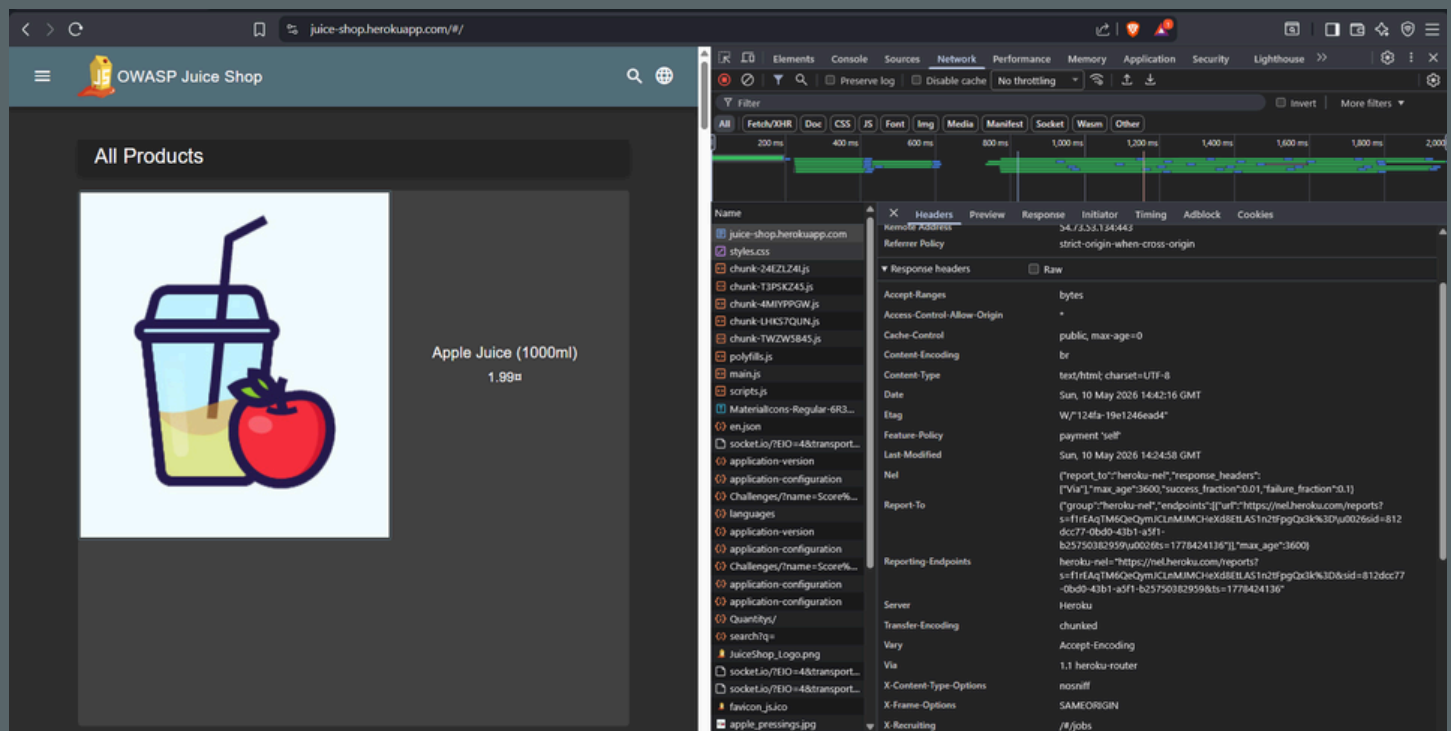
Risk Level : Medium

The website does not send a Content-Security-Policy (CSP). CSP controls which sources of content are allowed to load on the page. This content varies from scripts, images, styles, etc

Without Content-Security-Policy, the browser will load any resources requested by the page, even if they come from a malicious source

Affected Component : HTTP Response Headers

Screenshot 1 - Response header missing CSP header



BUSINESS IMPACT (SIMPLE LANGUAGE)

Without CSP , an attacker could inject malicious JavaScript into the website.

What could happen to a potential user:

- The user clicks a malicious link
- The attacker's script steals the user's cookies from the session
- The attacker takes over the user's account

REMEDIATION

Add this header to the server configuration
Content-Security-Policy: default-src 'self'; script-src 'self'

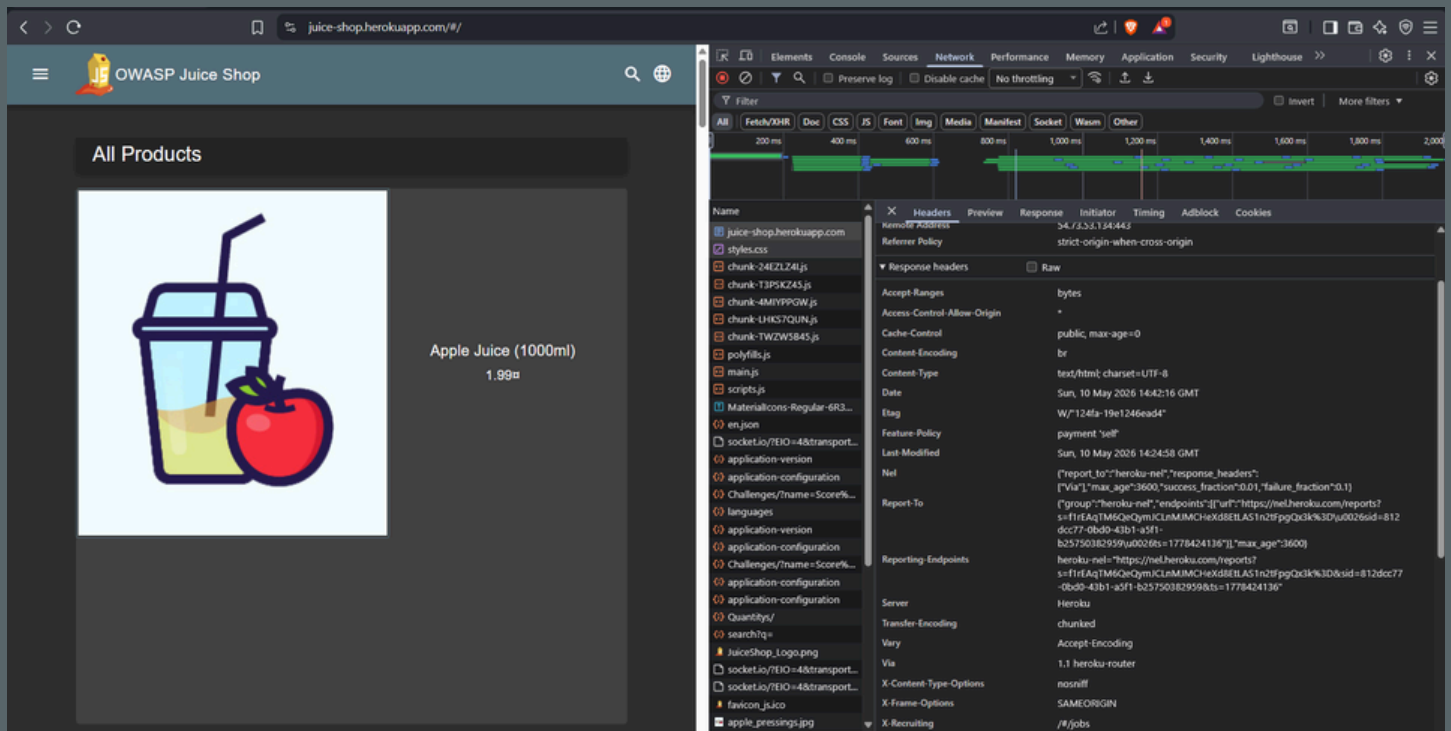
FINDING #2 : MISSING STRICT-TRANSPORT-SECURITY HEADER

Risk Level : Medium

The website does not enforce HTTPS through the HSTS(Strict-Transport-Security) header. While HTTPS is supported, browsers can still be forced to use insecure HTTP connections on first visit or after certificate errors.

Affected Component : HTTP Response Headers

Screenshot 2 - Reponse header missing HSTS header



BUSINESS IMPACT (SIMPLE LANGUAGE)

Without HSTS , An attacker on the same Wi-Fi network as a user could forcetheir browser to use HTTP instead of HTTPS.

What could happen to a potential user:

- User connects to coffee shop's public Wi-Fi
- Attacker intercepts the connection
- User's browser is forced to use HTTP
- Attacker reads login credentials and steals session tokens

This is called a "protocol downgrade attack" or "SSL stripping

REMEDIATION

Add this header to the server configuration
Strict-Transport-Security: max-age=31536000; includeSubDomains

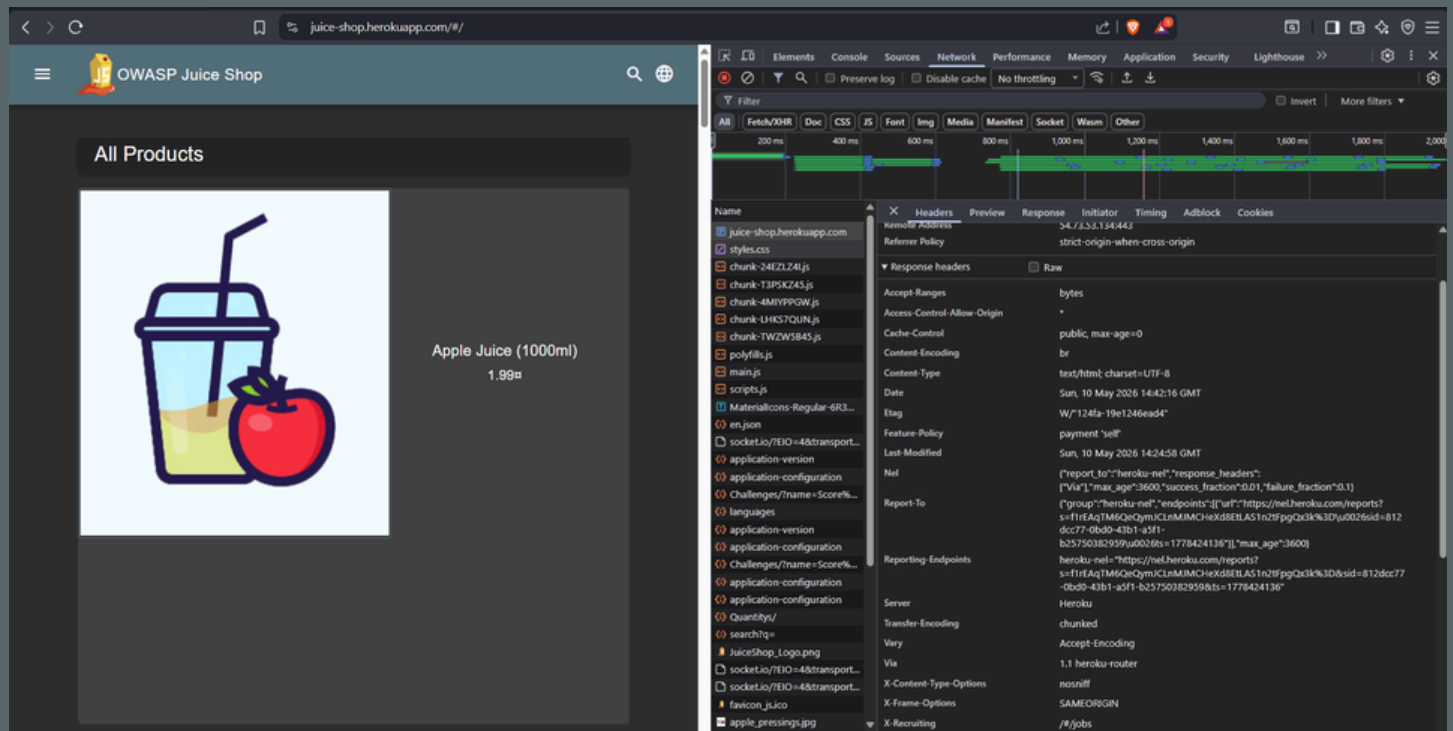
FINDING #3 : MISSING REFERRER-POLICY HEADER

Risk Level : Low

The Referrer-Policy header is missing. This controls how much referrer information is sent when users navigate to other sites.

Affected Component : HTTP Response Headers

Screenshot 2 - Response header missing Referrer-Policy Header



BUSINESS IMPACT (SIMPLE LANGUAGE)

When users click links to other websites, the destination site can see the full URL they came from, including any sensitive data in the URL.

REMEDIATION

Add this header to the server configuration
Referrer-Policy: strict-origin-when-cross-origin

FINDING #4 : MISSING PERMISSIONS-POLICY HEADER

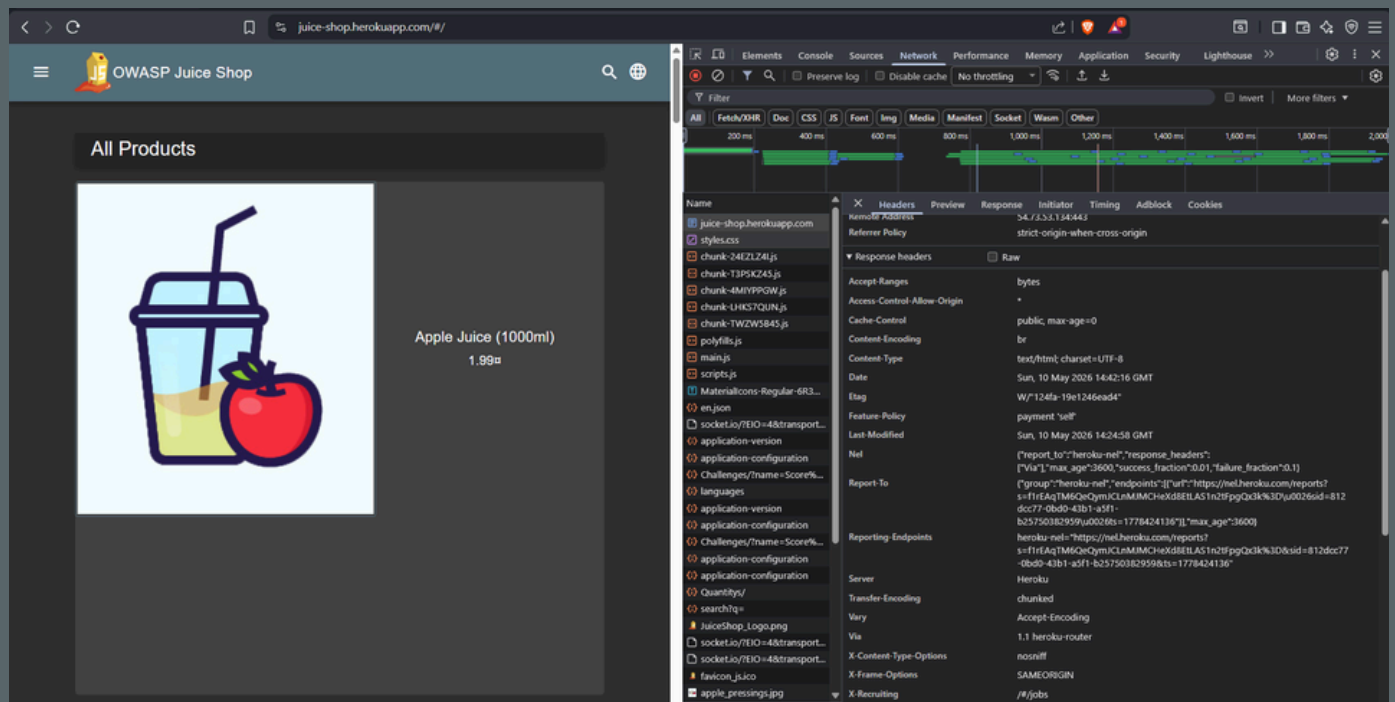
Risk Level : Low

The Permissions-Policy header is missing. The site uses the deprecated Feature-Policy header instead. This controls which browser features (camera, microphone, geolocation) can be accessed by the page.

Without Permissions-Policy, malicious scripts could request access to device features without user awareness.

Affected Component : HTTP Response Headers

Screenshot 2 - Response header missing Referer-Policy Header



BUSINESS IMPACT (SIMPLE LANGUAGE)

Without proper Permissions-Policy controls, here's what could happen:

1. An attacker finds a way to inject a malicious script into the website (through another vulnerability like XSS)
2. The malicious script requests access to your device's camera or microphone
3. Since no policy restricts these features, the browser may allow access or show a permission prompt
4. A user who clicks "Allow" could be recorded without knowing the request came from a malicious source. For a business website, this damages customer trust and could lead to privacy violations.

REMEDIATION

Replace the outdated Feature-Policy with:
Permissions-Policy: geolocation=(), microphone=(), camera=()

FINDING #5 : INSECURE COOKIE CONFIGURATION

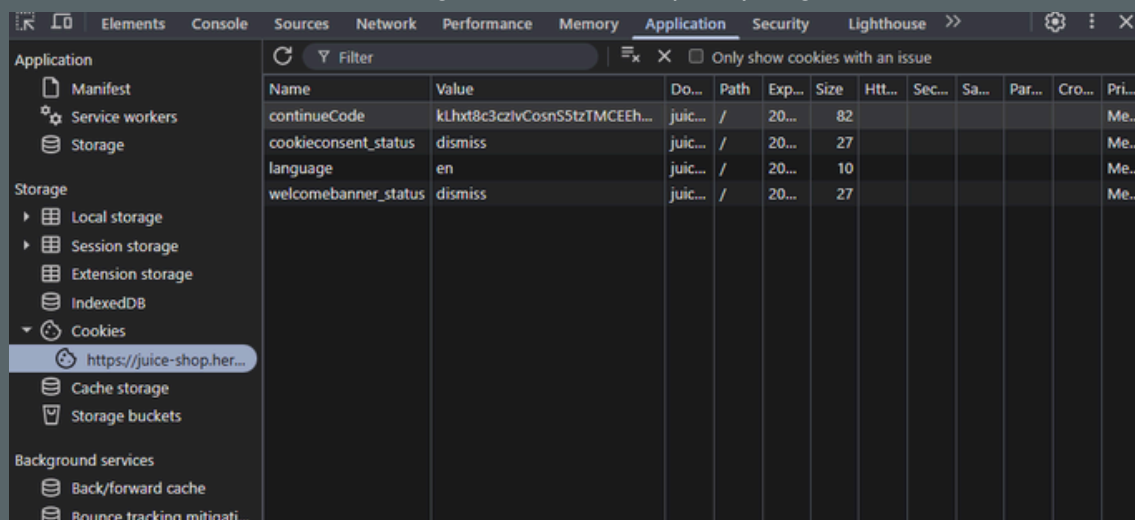
Risk Level : Medium

Multiple cookies are set without the Secure or HttpOnly flags. These flags are essential for protecting cookie data from theft and unauthorized access.

Affected Cookies :

- continueCode
- cookieconsent_status
- language
- welcomebanner_status

Screenshot 2 - Cookies missing Secure and HttpOnly flags



Name	Value	Do...	Path	Exp...	Size	Http...	Sec...	Sa...	Par...	Cro...	Pri...
continueCode	kLht8c3czlvCosnS5tzTMCEEh...	juic...	/	20...	82						Me...
cookieconsent_status	dismiss	juic...	/	20...	27						Me...
language	en	juic...	/	20...	10						Me...
welcomebanner_status	dismiss	juic...	/	20...	27						Me...

BUSINESS IMPACT (SIMPLE LANGUAGE)

Without proper cookie flags, two attacks become possible:

1. Missing Secure flag: If a user ever visits the site over HTTP (even once, or if forced by an attacker), all cookies are sent in plain text. An attacker on the same Wi-Fi network can capture them.
2. Missing HttpOnly flag: If an attacker finds a way to inject JavaScript (XSS attack), that script can read all cookies and send them to the attacker. This includes session tokens that keep users logged in.

Real-world impact: An attacker who steals a user's session cookie can:

- Log in as that user without needing their password
- Access their account, orders, and personal information
- Perform actions on behalf of the user

For a business, this leads to account takeover, data breach notification requirements, and loss of customer trust.

REMEDIATION

When creating cookies, always include these attributes:

- Set-Cookie: name=value; Secure; HttpOnly; SameSite=Lax
- Secure → Cookie only sent over HTTPS
- HttpOnly → JavaScript cannot read the cookie
- SameSite=Lax → Prevents cross-site request forgery (CSRF)

FINAL STATEMENT

FINAL RECOMMENDATION

Implement the recommendations above in priority order. The first three (CSP, HSTS, and cookie flags) address the medium-risk issues and should be completed within the next 30 days. The low-risk items can be scheduled for the next maintenance cycle.

If you have any questions about these findings or need assistance with implementation, please contact the security team.

Prepared by:
ORITONDA NEMALALE
Cyber Security Intern
Future Interns
CIN: FIT/MAY26/CS8151